INFORME DE PRUEBAS DE QA Y SEGURIDAD

Sistema Interoperable para la Gestión de Trámites Migratorios en Panamá

Herramientas: Apache JMeter 5.6.3 y OWASP ZAP 2.17.0

Fecha de evidencias: 22 de octubre de 2026 | Entorno: Windows 10, Docker Desktop, Spring Boot, Nginx y PostgreSQL

1. Objetivo y alcance

Documentar las pruebas iniciales de rendimiento y el análisis pasivo de seguridad realizados en el entorno local, con base en QA/Rama-03-QA-Seguridad.md y Documentacion/04-plan-de-pruebas.md del repositorio principal.

Correspondencia con el plan: CP-10 requiere una prueba de carga y métricas; CP-11 exige registrar hallazgos, evaluar riesgos, corregir y repetir el análisis. Este informe documenta la ejecución inicial, no el cierre completo de ambos casos.

2. Entorno y preparación

Servicio	Acceso local	Estado observado
Backend Spring Boot	http://127.0.0.1:8082	Health UP
Frontend Nginx	http://127.0.0.1:8083/html/index.html#/login	Formulario visible
PostgreSQL	localhost:5433	Contenedor saludable (sesión previa)
Proxy OWASP ZAP	localhost:8090	Captura de tráfico HTTP

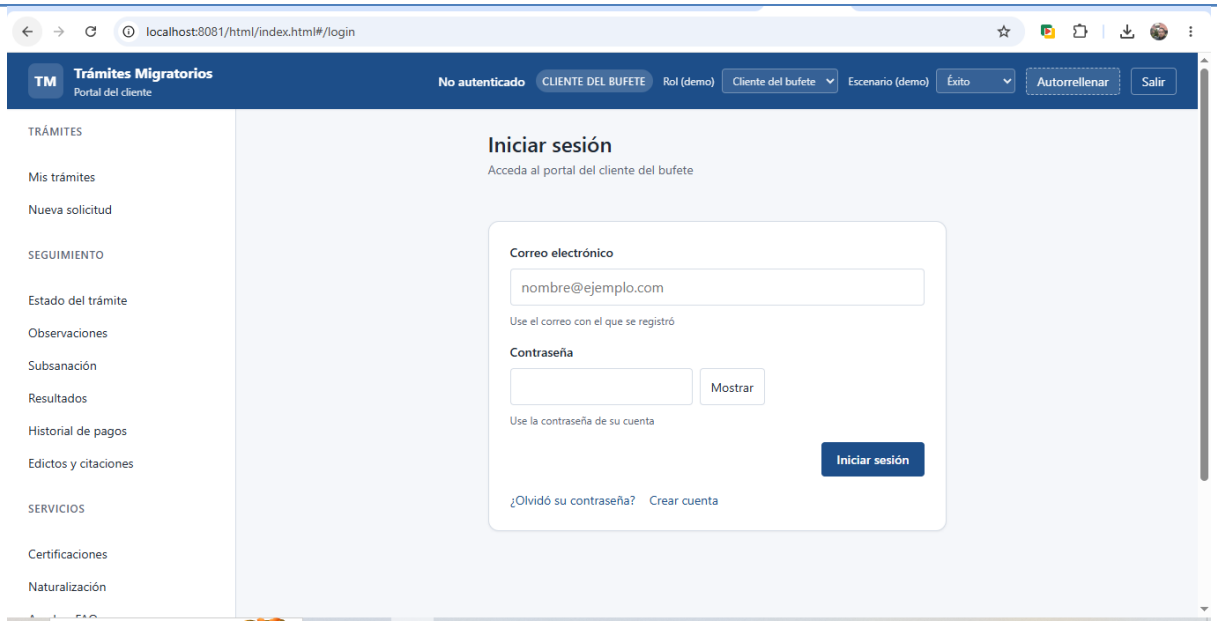


Figura 1. Formulario de inicio de sesión del frontend en navegador habitual.

3. Apache JMeter — CP-10

Configuración ejecutada: 10 usuarios virtuales, incremento gradual (ramp-up) de 10 segundos, dos iteraciones por usuario y petición GET a http://127.0.0.1:8082/actuator/health. Se realizaron 20 solicitudes en total.

Métrica	Resultado
Solicitudes	20
Tiempo promedio	24.25 ms
Mínimo / máximo	16 ms / 115 ms
Desviación estándar	20.93 ms
Errores JMeter	0.00 %
Rendimiento	2.3 solicitudes/segundo

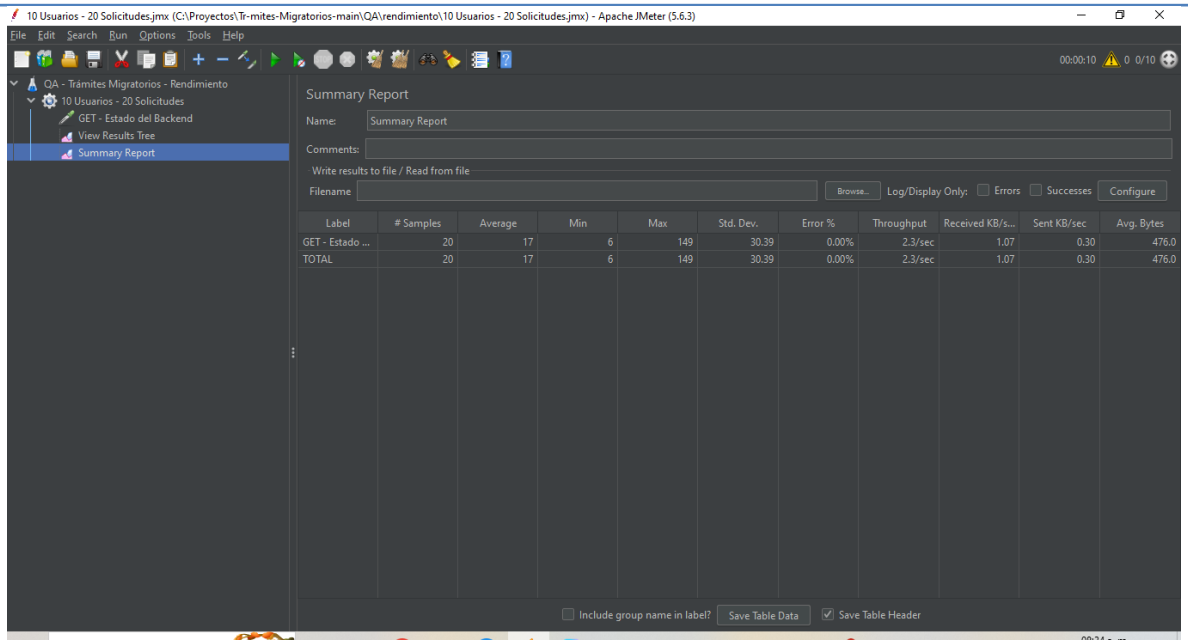


Figura 2. Summary Report: 20 solicitudes, 24.25 ms de media y 0 % de errores.

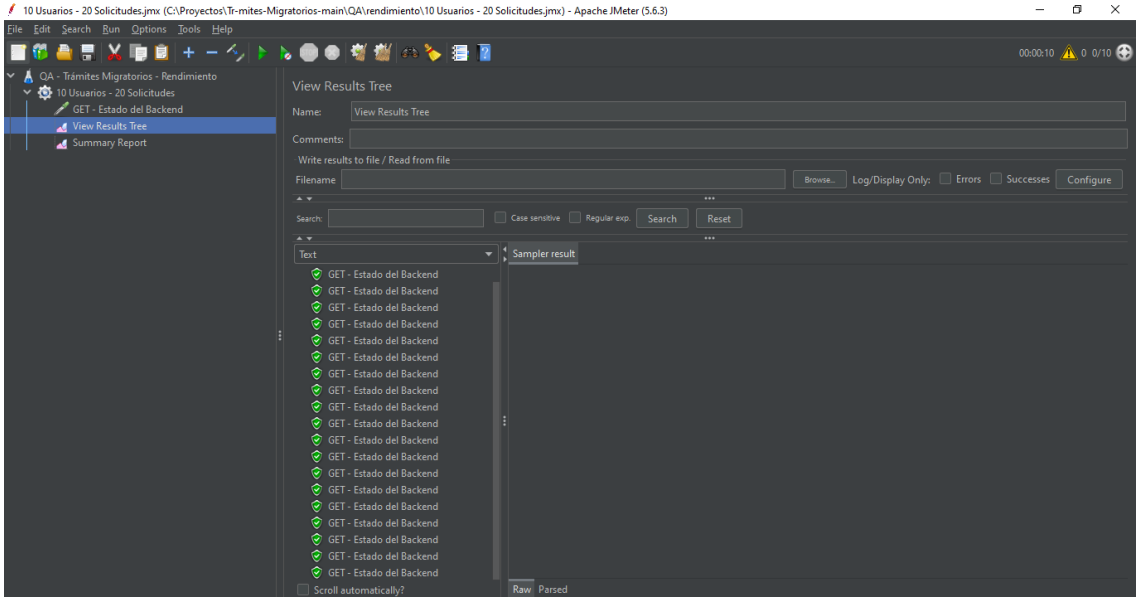


Figura 3. View Results Tree: solicitudes señaladas como satisfactorias.

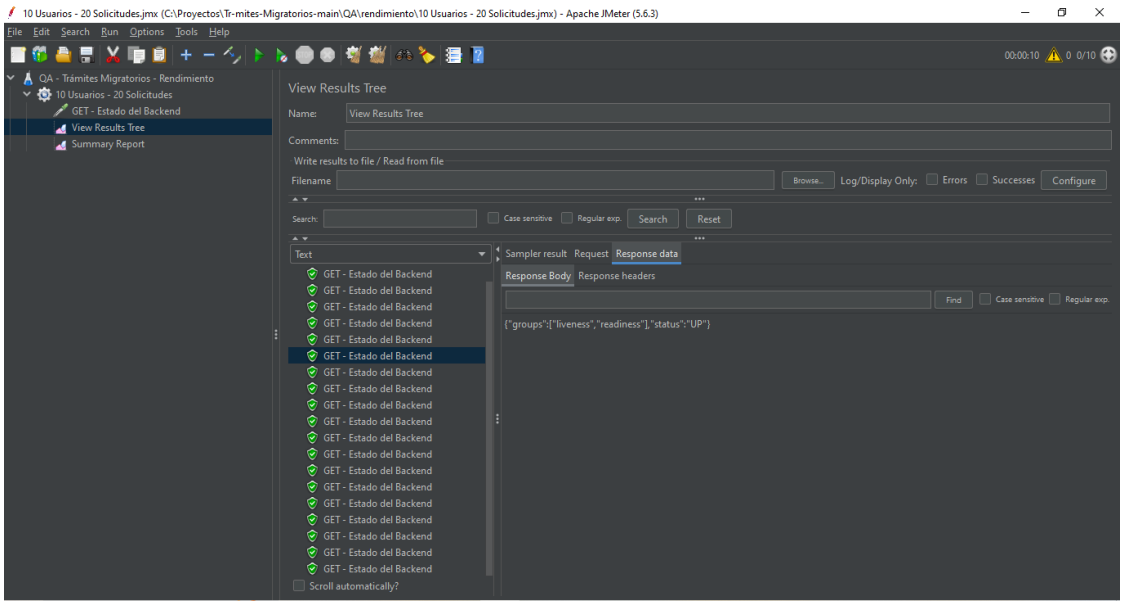


Figura 4. Cuerpo de respuesta de /actuator/health con status UP.

Interpretación: el endpoint de salud respondió satisfactoriamente bajo esta carga ligera. No se registraron aquí P95, CPU/memoria, picos de concurrencia, operaciones de negocio ni pruebas de caída de dependencias. Por tanto, CP-10 queda parcialmente evidenciado, no aprobado de forma integral.

4. OWASP ZAP — CP-11

Se abrió la aplicación mediante un navegador conectado al proxy de ZAP y se inspeccionó tráfico HTTP de 127.0.0.1:8083. Se utilizaron reglas de análisis pasivo, sin ejecutar un escaneo activo.

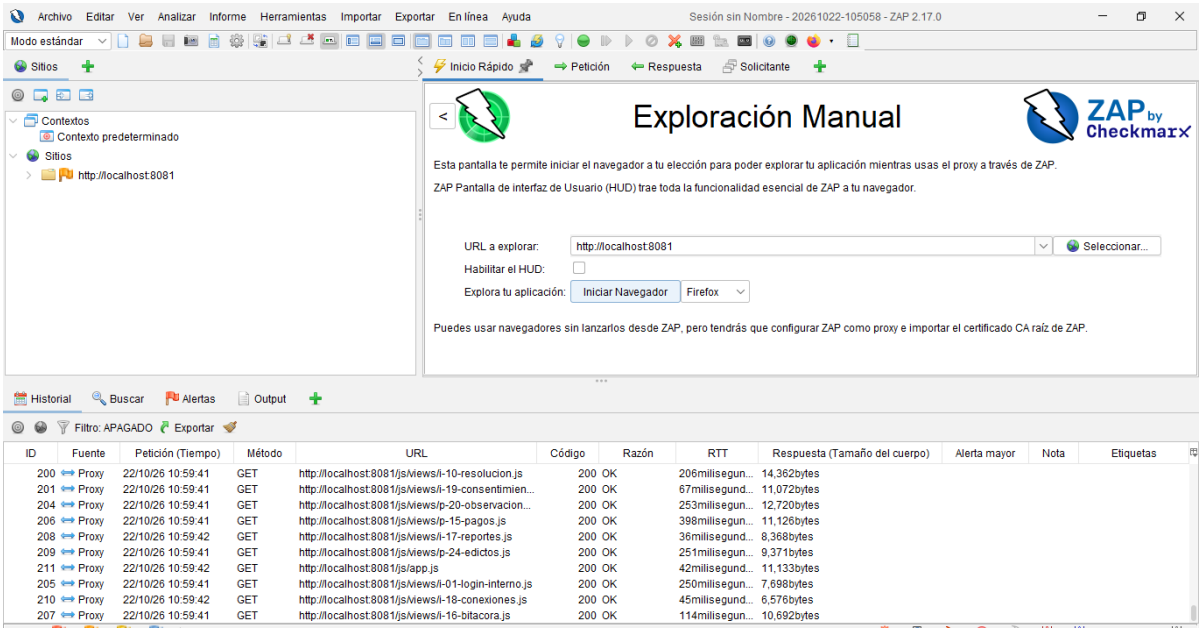


Figura 5. Historial del proxy con múltiples peticiones GET y respuestas HTTP 200.

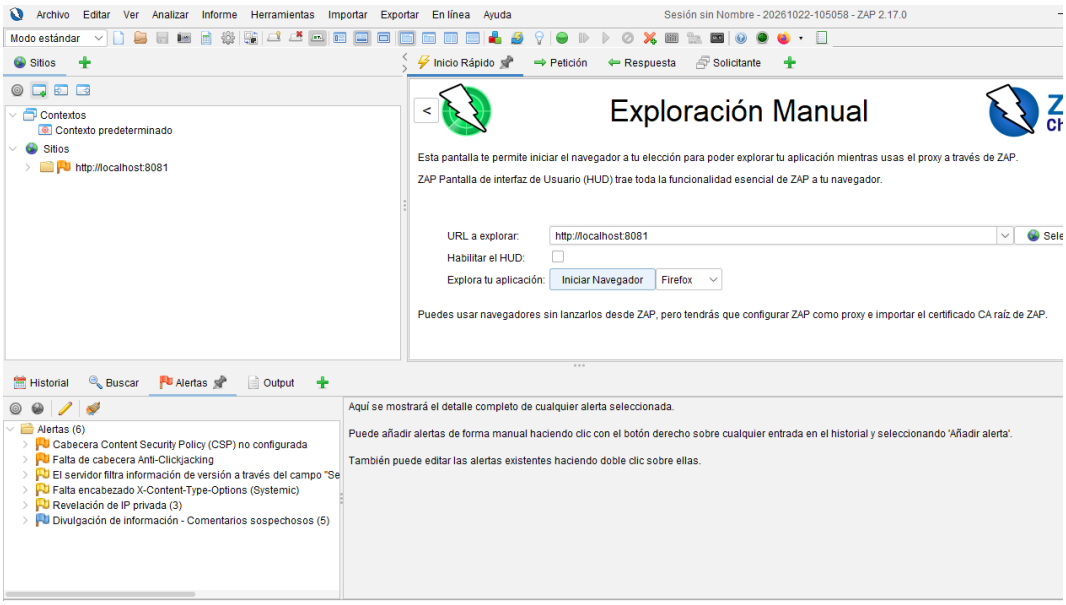


Figura 6. Vista general: 12 alertas detectadas.

4.1. Resumen de hallazgos

Código	Hallazgo	Riesgo ZAP
VULN-01	Falta Content-Security-Policy	Medio
VULN-02	Falta protección anti-clickjacking	Medio
VULN-03	Versión de Nginx expuesta	Bajo
VULN-04	Falta X-Content-Type-Options	Bajo
VULN-05	Permissions-Policy ausente	Bajo
OBS-06	Comentarios sospechosos en JavaScript	Informativo

VULN-01. Content-Security-Policy

Riesgo medio, confianza alta. La respuesta no declara CSP. Recomendar una política adaptada a scripts, estilos y API; probarla antes de aplicarla.



Figura 7. CSP ausente en /html/index.html.

VULN-02. Anti-clickjacking

Riesgo medio, confianza media. Falta una protección reconocida como X-Frame-Options o CSP frame-ancestors; revisar necesidad real de incrustación.

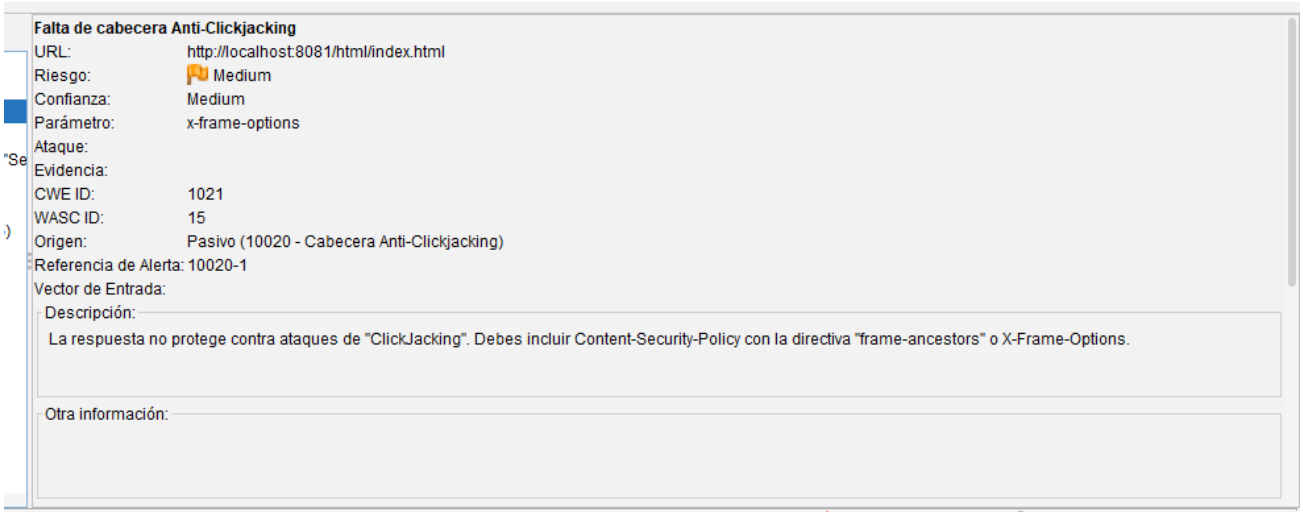


Figura 8. Falta cabecera anti-clickjacking en /html/index.html.

VULN-03. Versión del servidor

Riesgo bajo, confianza alta. Se expone la versión del servidor; revisar server_tokens off y mantener Nginx actualizado.

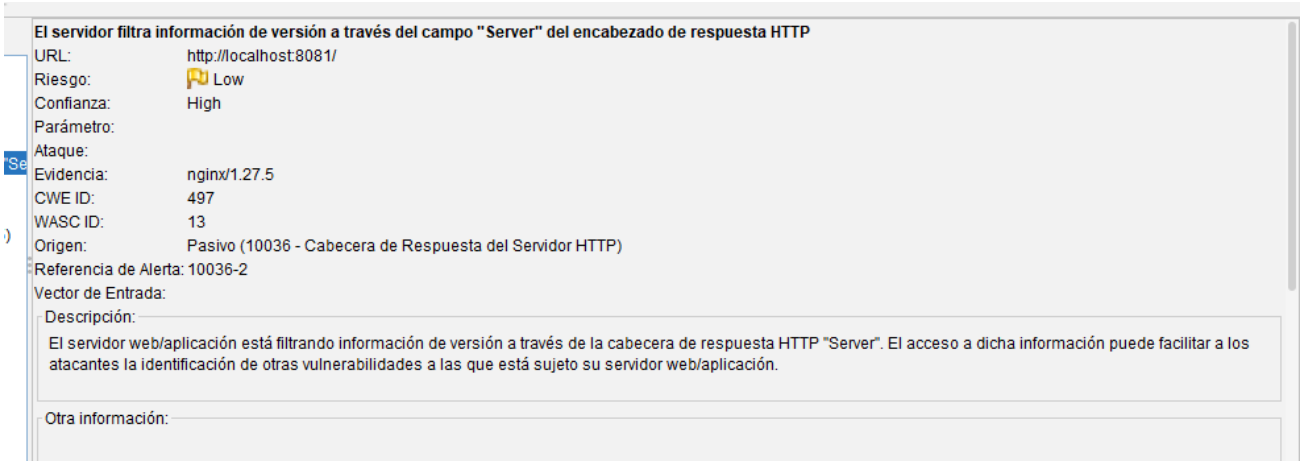


Figura 9. Encabezado Server revela nginx/1.27.5.

VULN-04. X-Content-Type-Options

Riesgo bajo, confianza media. Falta X-Content-Type-Options: nosniff; verificar también tipos MIME correctos.

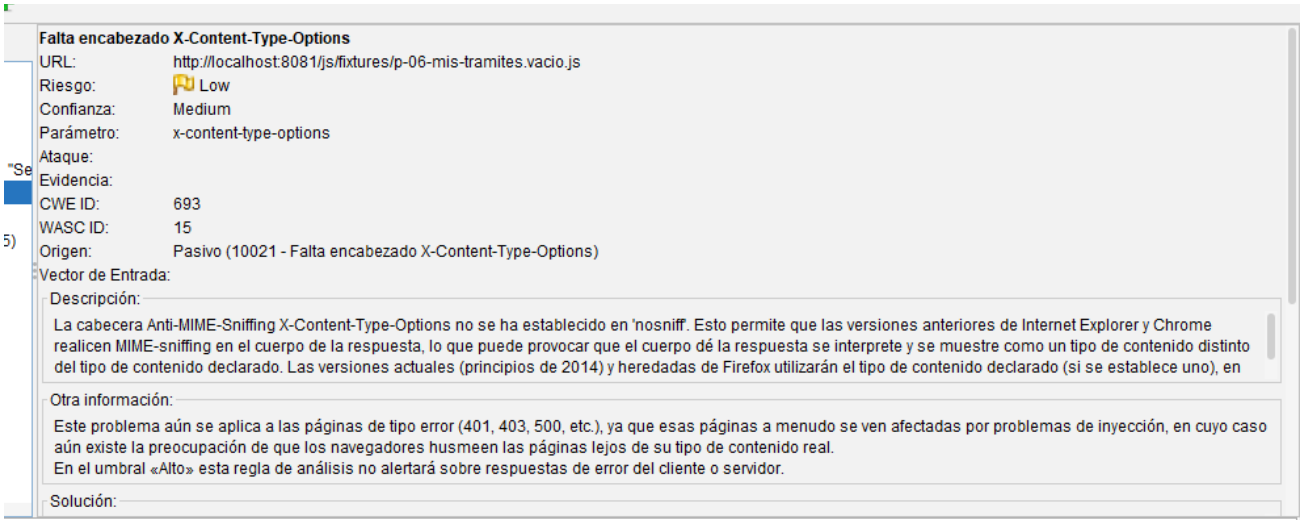


Figura 10. Falta nosniff en un archivo JavaScript.

VULN-05. Permissions-Policy ausente

Riesgo bajo, confianza media. La respuesta no declara Permissions-Policy; revisar las funcionalidades del navegador que debe permitir la aplicación.



Figura 11. Ausencia de Permissions-Policy en la respuesta del frontend.

OBS-06. Comentarios sospechosos

Informativo, confianza media. El comentario menciona una distinción entre demo y producción; revisar si describe reglas efectivas o solo documentación interna.

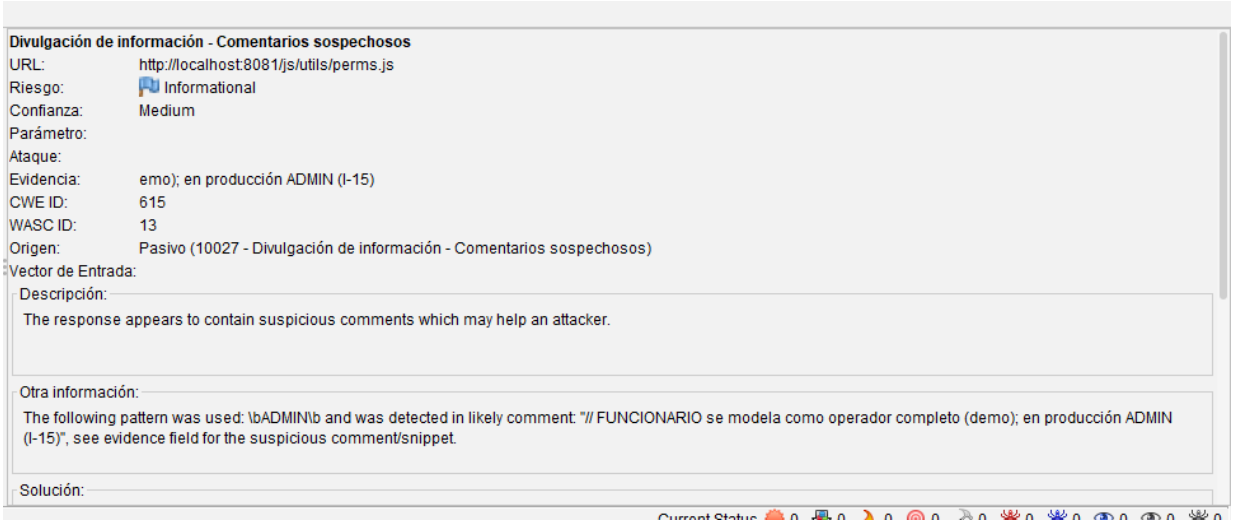


Figura 12. Comentario en js/utils/perms.js sobre FUNCIONARIO y ADMIN.

5. Conclusiones

JMeter: ejecución inicial satisfactoria de 20 solicitudes contra el endpoint de salud, sin errores registrados y con promedio de 24.25 ms. Esta evidencia no basta para certificar el rendimiento de los procesos de negocio.

ZAP: el análisis pasivo identificó 12 alertas: dos de riesgo medio, siete de riesgo bajo y tres informativas. La detección no demuestra explotación; cada hallazgo requiere validación, corrección si procede y nueva prueba.

6. Pendientes según el plan oficial

- CP-10: medir P95, CPU y memoria; probar operaciones principales, concurrencia mayor y fallas de dependencias; acordar umbrales.
- CP-11: revisar autorización, autenticación, sesiones, entradas y API; realizar escaneo activo solo en entorno controlado con autorización del equipo.
- Registrar responsable, severidad, estado y fecha de corrección por incidencia; repetir JMeter y ZAP tras los cambios.
- Conservar archivos .jmx, resultados CSV/JTL, reportes de ZAP y capturas en el repositorio QA.
- Completar otras pruebas funcionales, legales y de integración previstas por la rama; este documento no las acredita.

7. Fuentes internas

Repositorio suministrado: QA/Rama-03-QA-Seguridad.md; Documentacion/04-plan-de-pruebas.md; README.md. Evidencias: capturas de JMeter y OWASP ZAP compartidas durante la ejecución.